

REDES PRIVATIVAS

AULA 2 – Cibersegurança em redes: Anatomia de um ataque cibernético

alura + FIA/P

PARA EMPRESAS

PROFESSOR ALMIR MEIRA ALVES



<https://www.linkedin.com/in/almirmeira/>

Profissional que atua desde 1994 nas áreas de Segurança da Informação, Telecomunicações, Engenharia e Educação Tecnológica e em Informática.

Amplo conhecimento em estratégias e operações de Cybersecurity, com conhecimento aprofundado em ferramental enterprise de cibersegurança

- + **Diretor Acadêmico da CECyber**
- + **Responsável pelo programa de PÓS-GRADUAÇÃO da CECyber**
- + **Professor de Cybersecurity do MBA em Data Science PECE POLI USP**
- + **Ex-Coordenador da Fatec, FIAP e Universidade Braz Cubas**
- + **Especialista em Criptografia e Segurança em Redes**

O QUE VEREMOS HOJE

Falaremos sobre Cibersegurança

PARTE 1:

Anatomia de um ataque cibernético: Visão do atacante e atividades de detecção

PARTE 2:

Melhores práticas de Defesa Cibernética: Investigação, contenção, resposta e mitigação

RECURSOS PARA AS ATIVIDADES PRÁTICAS

Link para baixar os recursos do drive:

[MATERIAIS DE APOIO - REDES PRIVATIVAS](#)

PARTE 1

+ ANATOMIA DE UM ATAQUE CIBERNÉTICO



O QUE IREMOS APRENDER HOJE?

- Exemplos de ataques cibernéticos
- Compreender o **modus operandi** de um hacker malicioso
- Conhecer as principais **ferramentas de detecção** de ataques cibernéticos.

Introdução



Um incidente de segurança da informação pode ser definido como qualquer evento que comprometa a **confidencialidade, integridade ou disponibilidade de informações**.

- Em termos mais simples, é uma situação onde dados ou sistemas de uma organização são **acessados, alterados, destruídos ou tornados inacessíveis de maneira não autorizada**.
- Esses incidentes podem variar desde ataques cibernéticos, como vírus e malware, até falhas humanas, como a perda de um dispositivo contendo informações sensíveis.
- A importância de identificar e responder rapidamente a esses incidentes é crucial para minimizar danos e proteger os ativos de informação da organização.

Exemplos de incidentes

MOVEit	2023 - Comissão Eleitoral do Reino Unido	Serviço de Polícia da Irlanda do Norte (PSNI)
Este ataque envolveu o uso de uma vulnerabilidade de dia zero (0-DAY) em um software popular para acessar os ambientes dos clientes e extrair dados. Estima-se que mais de 2.600 organizações e 83 milhões de pessoas foram afetadas.	Cibercriminosos roubaram informações pessoais de cerca de 40 milhões de eleitores do registro eleitoral. O ataque foi atribuído a um servidor Microsoft Exchange não corrigido	Um funcionário publicou accidentalmente dados internos confidenciais em resposta a uma solicitação de Informação. Este incidente destacou a importância de controles internos rigorosos



Exemplos de incidentes

MOVEit

The file-transfer

2023 - Comissão
Eleitoral do
Reino Unido

**Deputy PM Oliver Dowden
accuses China of targeting
millions of UK voters
in cyber attack**

Serviço de
Polícia da Irlanda
do Norte (PSNI)

PSNI
200
head

12th December 2023, 07:10 EST

Share

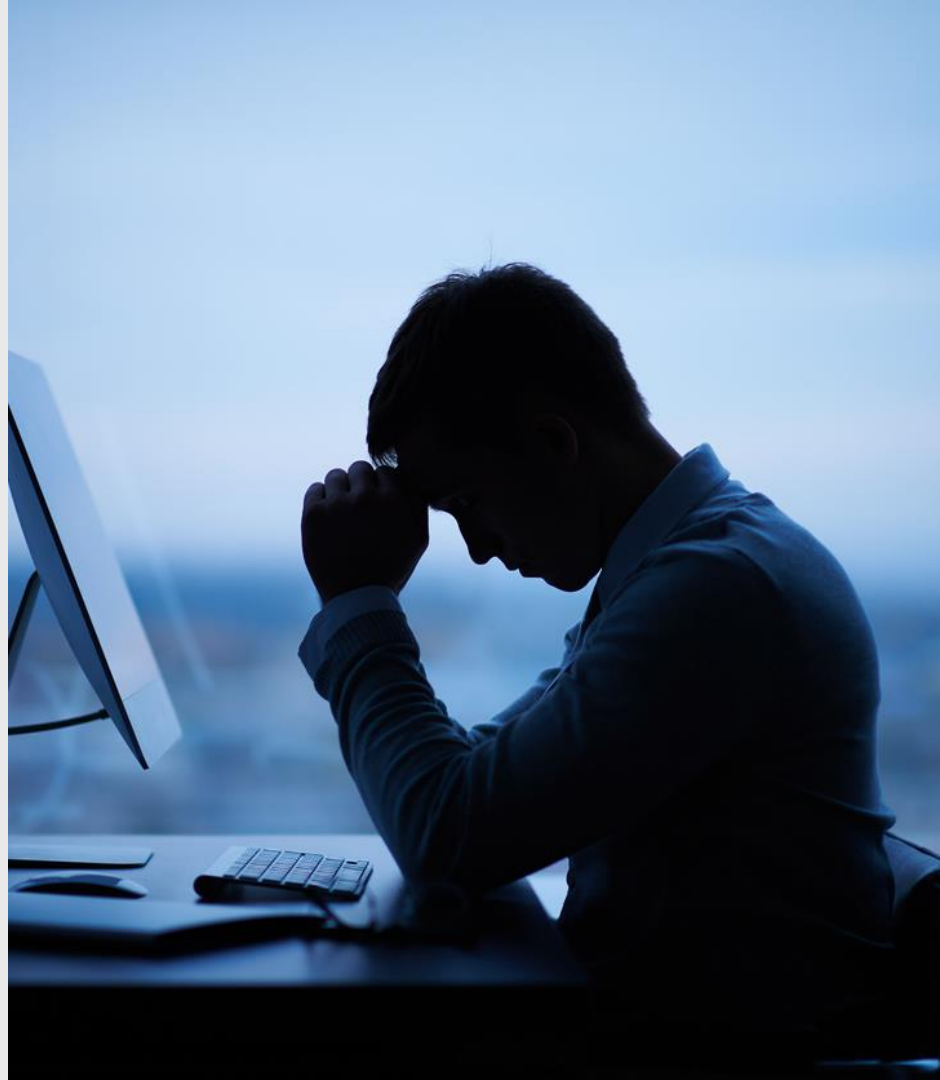
By J...
BBC
corres



The... of almost 10,000 PSNI
employees released in error

**Almost 200 officers are seeking ill-health
retirement from the Police Service of Northern
Ireland (PSNI), as it deals with the fall-out of a
major data breach, a Westminster committee
has heard.**

O QUE FAZER QUANDO ACONTECE UM ATAQUE CIBERNÉTICO?



MITRE ATT&ACK - Decompondo um ataque

layer x + <https://mitre-attack.github.io/attack-navigator/>

Reconnaissance 10 techniques Resource Development 8 techniques Initial Access 9 techniques Execution 14 techniques Persistence 19 techniques Privilege Escalation 13 techniques Defense Evasion 42 techniques Credential Access 17 techniques Discovery 31 techniques Lateral Movement 9 techniques Collection 17 techniques Command and Control 16 techniques Exfiltration 9 techniques Impact 13 techniques

Active Scanning (0/3) Gather Victim Host Information (0/4) Gather Victim Identity Information (0/3) Gather Victim Network Information (0/6) Gather Victim Org Information (0/4) Phishing for Information (0/3) Search Closed Sources (0/2) Search Open Technical Databases (0/5) Search Open Websites/Domains (0/3) Search Victim-Owned Websites

Acquire Access Acquire Infrastructure (0/6) Compromise Accounts (0/3) Compromise Infrastructure (0/7) Develop Capabilities (0/4) Establish Accounts (0/3) Obtain Capabilities (0/6) Stage Capabilities (0/5) Trusted Relationship Valid Accounts (0/4)

Drive-by Compromise Exploit Public-Facing Application External Remote Services Hardware Additions Phishing (0/3) Replication Through Removable Media Supply Chain Compromise (0/3) Inter-Process Communication (0/3) Native API Scheduled Task/Job (0/5) Serverless Executor Shared Modules Software Deployment Tools System Services User Execution (0/3) Windows Management Instrumentation

Cloud Administration Command Command and Scripting Interpreter (0/9) Container Administration Command Deploy Container Exploitation for Client Execution Inter-Process Communication (0/3) Native API Scheduled Task/Job (0/5) Serverless Executor Shared Modules Software Deployment Tools System Services User Execution (0/3) Windows Management Instrumentation

Account Manipulation (0/5) BITS Jobs Boot or Logon Autostart Permission Abuse Elevation Control Mechanism (0/4) Access Token Manipulation (0/5) BITS Jobs Adversary-in-the-Middle (0/3) Brute Force (0/4) Credentials from Password Storage

Abuse Elevation Control Mechanism (0/4) Access Token Manipulation (0/5) BITS Jobs Adversary-in-the-Middle (0/3) Application Window Discovery Browser Information Discovery

Account Discovery (0/4) Application Window Discovery Browser Information Discovery

Exploitation of Remote Services Internal Spearphishing Lateral Tunnel

Adversary-in-the-Middle (0/3) Archive Collected Data (0/3) Audio Capture

Application Layer Protocol (0/4) Communication Through Removable Media

Automated Exfiltration (0/1) Data Transfer Size Limits Data Destruction Data Encrypted for Impact Exfiltration Over Alternative Protocol (0/3) Exfiltration Over C2 Channel Disk Wipe (0/2) Exfiltration Over Other Network Medium (0/1) Exfiltration Over Physical Medium (0/1) Exfiltration Over Web Service (0/3) Network Denial of Service (0/2) Resource Hijacking Scheduled Transfer System Shutdown/Reboot Transfer Data to Cloud Account

ata coding (0/2) ata bfusation (0/3) namic ssolution (0/3) ripted hannel (0/2) llback hannels gress Tool ansfer lulti-Stage hannels on-Application yer Protocol on-Standard rt otocol nneling ocky (0/4) mote Access ftware affic gnaling (0/2) eb Service (0/3)

TTPs
TÁTICAS
TÉCNICAS
PROCEDIMENTOS

TTPs — Tough!

TOOLS — Challenging

NETWORK/HOST ARTIFACTS — Annoying

DOMAIN NAMES — Simple

IP ADDRESSES — Easy

HASH VALUES — Trivial

MITRE ATT&CK® Navigator v4.8.2

legend



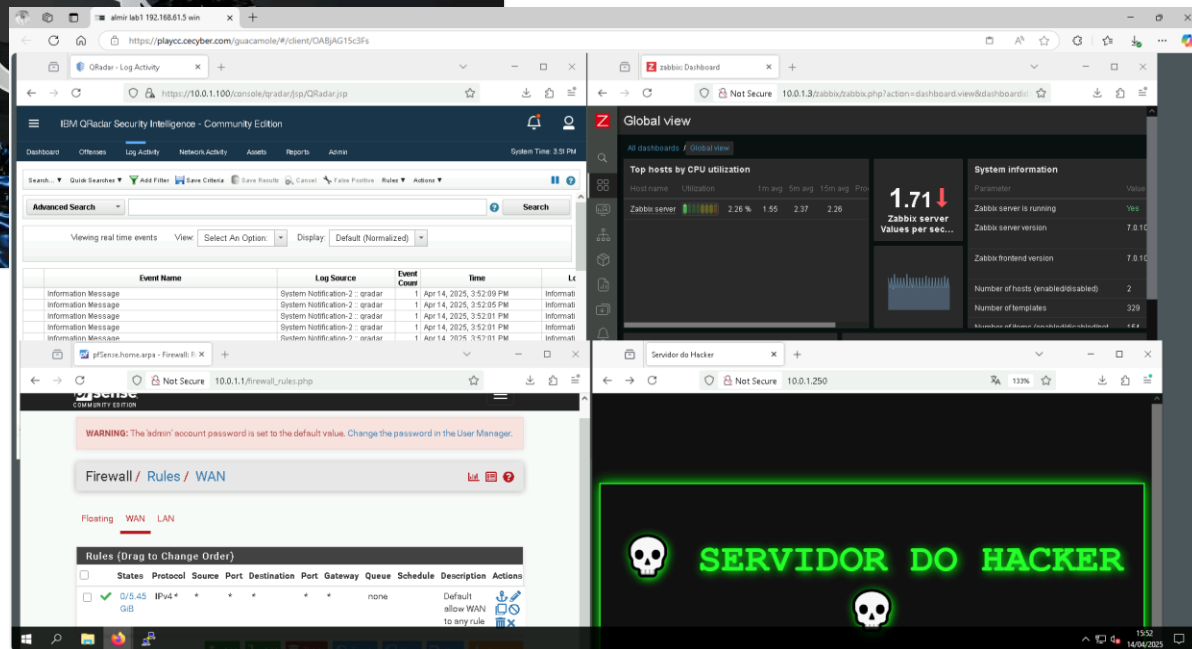
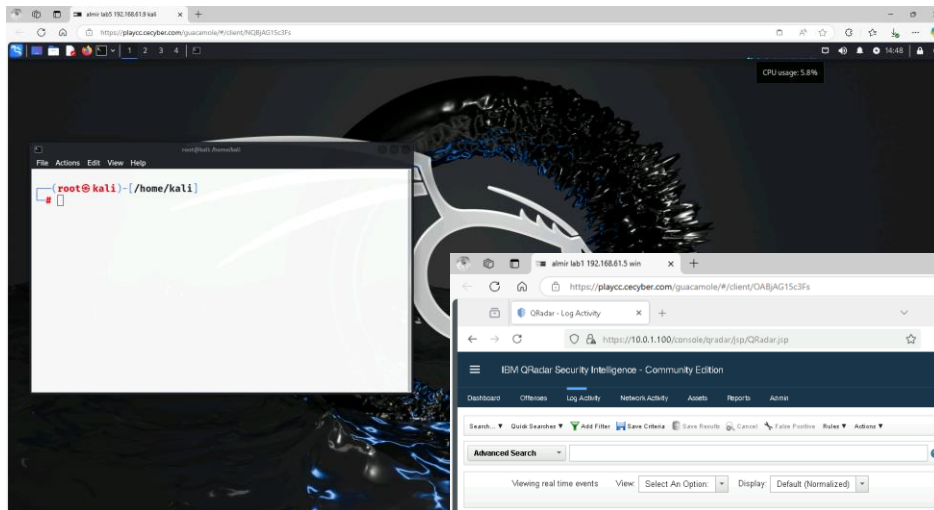
ANATOMIA DE UM ATAQUE

**COMO É O INÍCIO TÍPICO DE UM
ATAQUE**

NA ANATOMIA DO ATAQUE, A ABORDAGEM É 360°

**PERSPECTIVA DE DEFESA
CIBERNÉTICA E SUAS FERRAMENTAS
(SIEM, FIREWALL, MONITORAMENTO
DE REDES)**

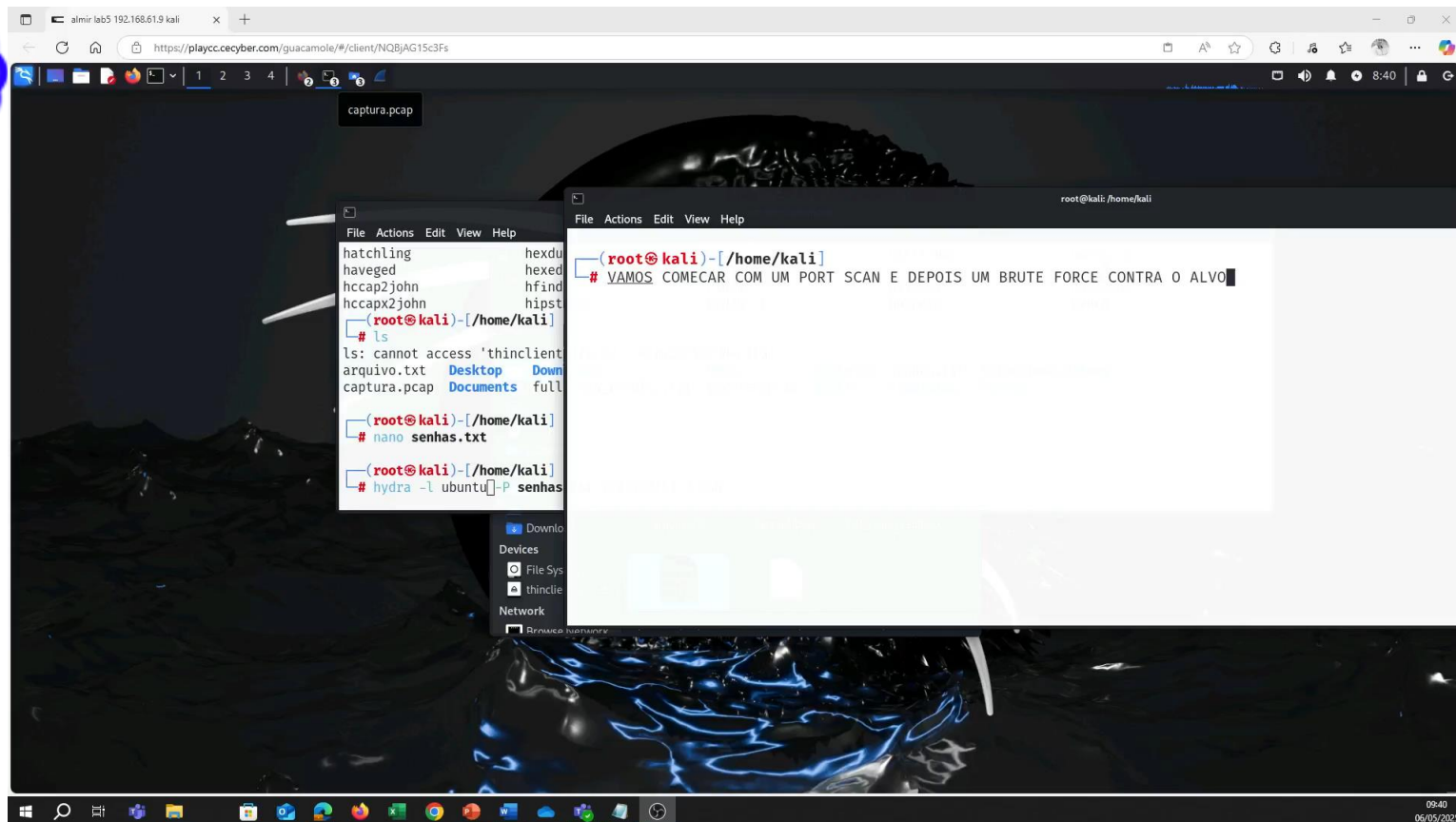
**PERSPECTIVA DO
ATACANTE**



SERVIDOR DO HACKER

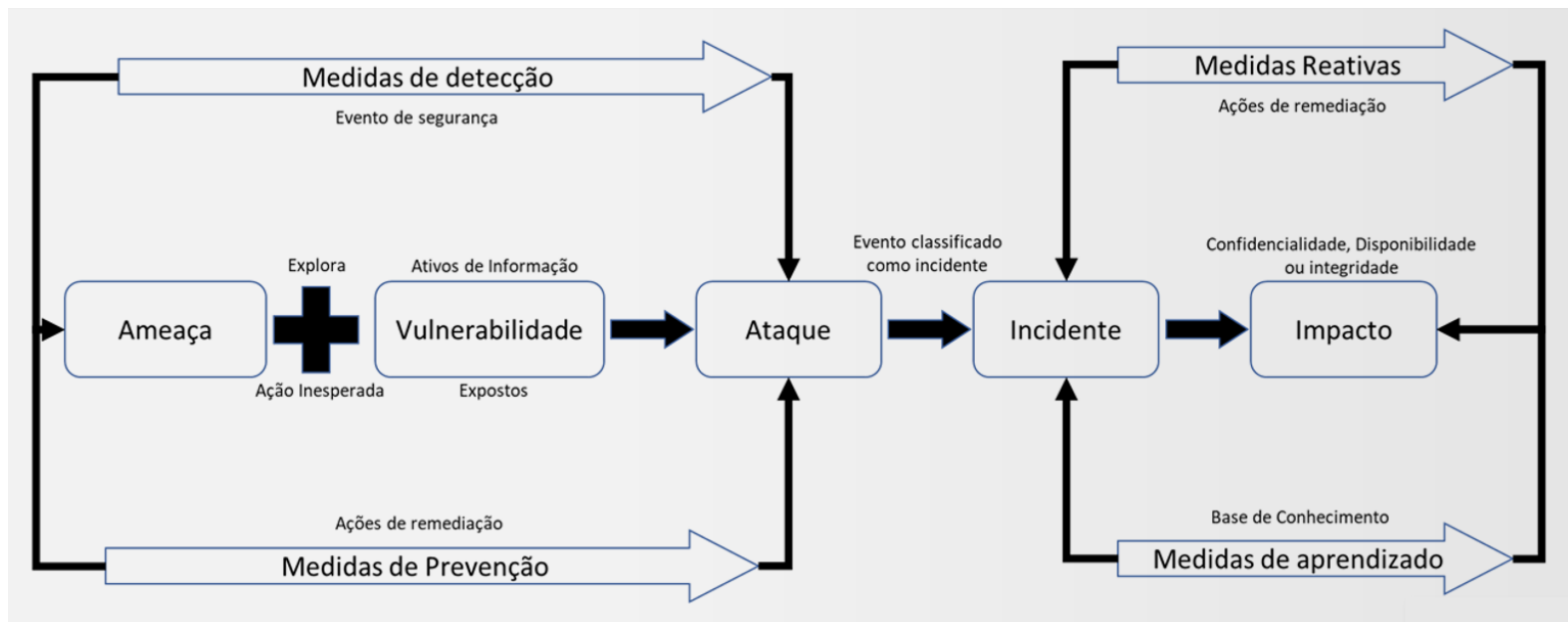


COMO O ATAQUE FOI REALIZADO





O QUE É UM INCIDENTE DE SEGURANÇA DA INFORMAÇÃO



COMO O ATAQUE FOI DETECTADO

CECyber Play x almir lab1 192.168.61.5 win x cecpa - Proxmox Virtual Environ x Nova guia

https://playcccecyber.com/guacamole/#/client/OABJAG15c3Fs

QRadar - Log Activity

https://10.0.1.100/console/qradar/jsp/QRadar.jsp

IBM QRadar Security Intelligence - Community Edition

Dashboard Offenses Log Activity Network Activity Assets Reports Admin

System Time: 9:48 AM

Search... Quick Searches Add Filter Save Criteria Save Results Cancel False Positive Rules Actions

Quick Filter

Viewing real time events View Select An Option: Display: Default (Normalized)

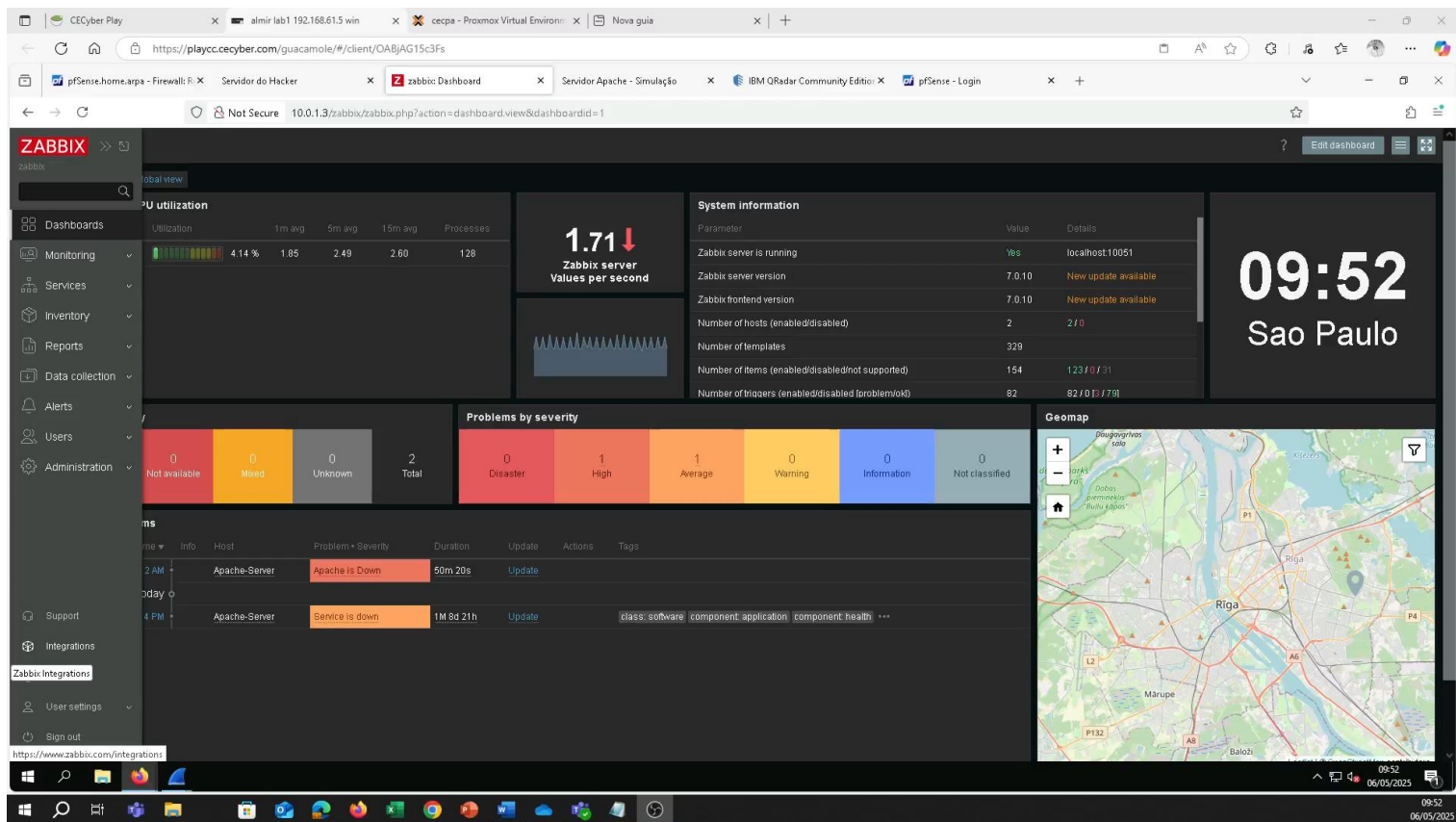
Event Name	Log Source	Event Count	Time	Low Level Category	Source IP	Source Port	Destination IP	Destination Port	Username	Magnitude
Tentativa de Port Scan	Custom Rule Engine-8 : qradar	1	May 6, 2025, 9:49:00 AM	NMAP Reconnaissance	95.213.200.250	41575	10.0.1.11	40135	N/A	■■■■■■■■■■
Tentativa de Port Scan	Custom Rule Engine-8 : qradar	1	May 6, 2025, 9:49:00 AM	NMAP Reconnaissance	95.213.200.250	41575	10.0.1.11	30706	N/A	■■■■■■■■■■
Tentativa de Port Scan	Custom Rule Engine-8 : qradar	1	May 6, 2025, 9:49:00 AM	NMAP Reconnaissance	95.213.200.250	41575	10.0.1.11	2221	N/A	■■■■■■■■■■
Tentativa de Port Scan	Custom Rule Engine-8 : qradar	1	May 6, 2025, 9:49:00 AM	NMAP Reconnaissance	95.213.200.250	41575	10.0.1.11	12554	N/A	■■■■■■■■■■
Tentativa de Port Scan	Custom Rule Engine-8 : qradar	1	May 6, 2025, 9:49:00 AM	NMAP Reconnaissance	95.213.200.250	41575	10.0.1.11	63612	N/A	■■■■■■■■■■
Tentativa de Port Scan	Custom Rule Engine-8 : qradar	1	May 6, 2025, 9:49:00 AM	NMAP Reconnaissance	95.213.200.250	41575	10.0.1.11	36297	N/A	■■■■■■■■■■
Tentativa de Port Scan	Custom Rule Engine-8 : qradar	1	May 6, 2025, 9:49:00 AM	NMAP Reconnaissance	95.213.200.250	41575	10.0.1.11	52954	N/A	■■■■■■■■■■
Tentativa de Port Scan	Custom Rule Engine-8 : qradar	1	May 6, 2025, 9:49:00 AM	NMAP Reconnaissance	95.213.200.250	41575	10.0.1.11	59032	N/A	■■■■■■■■■■
Tentativa de Port Scan	Custom Rule Engine-8 : qradar	1	May 6, 2025, 9:49:00 AM	NMAP Reconnaissance	95.213.200.250	41575	10.0.1.11	30710	N/A	■■■■■■■■■■
Tentativa de Port Scan	Custom Rule Engine-8 : qradar	1	May 6, 2025, 9:49:00 AM	NMAP Reconnaissance	95.213.200.250	41575	10.0.1.11	48065	N/A	■■■■■■■■■■
Tentativa de Port Scan	Custom Rule Engine-8 : qradar	1	May 6, 2025, 9:49:00 AM	NMAP Reconnaissance	95.213.200.250	41575	10.0.1.11	37656	N/A	■■■■■■■■■■
Tentativa de Port Scan	Custom Rule Engine-8 : qradar	1	May 6, 2025, 9:49:00 AM	NMAP Reconnaissance	95.213.200.250	41575	10.0.1.11	56762	N/A	■■■■■■■■■■
Tentativa de Port Scan	Custom Rule Engine-8 : qradar	1	May 6, 2025, 9:49:00 AM	NMAP Reconnaissance	95.213.200.250	41575	10.0.1.11	45541	N/A	■■■■■■■■■■
Tentativa de Port Scan	Custom Rule Engine-8 : qradar	1	May 6, 2025, 9:49:00 AM	NMAP Reconnaissance	95.213.200.250	41575	10.0.1.11	34089	N/A	■■■■■■■■■■
Tentativa de Port Scan	Custom Rule Engine-8 : qradar	1	May 6, 2025, 9:49:00 AM	NMAP Reconnaissance	95.213.200.250	41575	10.0.1.11	39224	N/A	■■■■■■■■■■
Tentativa de Port Scan	Custom Rule Engine-8 : qradar	1	May 6, 2025, 9:49:00 AM	NMAP Reconnaissance	95.213.200.250	41575	10.0.1.11	23663	N/A	■■■■■■■■■■
Tentativa de Port Scan	Custom Rule Engine-8 : qradar	1	May 6, 2025, 9:49:00 AM	NMAP Reconnaissance	95.213.200.250	41575	10.0.1.11	37410	N/A	■■■■■■■■■■
Tentativa de Port Scan	Custom Rule Engine-8 : qradar	1	May 6, 2025, 9:49:00 AM	NMAP Reconnaissance	95.213.200.250	41575	10.0.1.11	42864	N/A	■■■■■■■■■■
Tentativa de Port Scan	Custom Rule Engine-8 : qradar	1	May 6, 2025, 9:49:00 AM	NMAP Reconnaissance	95.213.200.250	41575	10.0.1.11	37667	N/A	■■■■■■■■■■
Tentativa de Port Scan	Custom Rule Engine-8 : qradar	1	May 6, 2025, 9:49:00 AM	NMAP Reconnaissance	95.213.200.250	41575	10.0.1.11	44136	N/A	■■■■■■■■■■
Tentativa de Port Scan	Custom Rule Engine-8 : qradar	1	May 6, 2025, 9:49:00 AM	NMAP Reconnaissance	95.213.200.250	41575	10.0.1.11	54368	N/A	■■■■■■■■■■
Tentativa de Port Scan	Custom Rule Engine-8 : qradar	1	May 6, 2025, 9:49:00 AM	NMAP Reconnaissance	95.213.200.250	41575	10.0.1.11	11300	N/A	■■■■■■■■■■
Tentativa de Port Scan	Custom Rule Engine-8 : qradar	1	May 6, 2025, 9:49:00 AM	NMAP Reconnaissance	95.213.200.250	41575	10.0.1.11	29610	N/A	■■■■■■■■■■
Tentativa de Port Scan	Custom Rule Engine-8 : qradar	1	May 6, 2025, 9:49:00 AM	NMAP Reconnaissance	95.213.200.250	41575	10.0.1.11	25465	N/A	■■■■■■■■■■
Tentativa de Port Scan	Custom Rule Engine-8 : qradar	1	May 6, 2025, 9:49:00 AM	NMAP Reconnaissance	95.213.200.250	41575	10.0.1.11	22804	N/A	■■■■■■■■■■
Tentativa de Port Scan	Custom Rule Engine-8 : qradar	1	May 6, 2025, 9:49:00 AM	NMAP Reconnaissance	95.213.200.250	41575	10.0.1.11	12150	N/A	■■■■■■■■■■
Tentativa de Port Scan	Custom Rule Engine-8 : qradar	1	May 6, 2025, 9:49:00 AM	NMAP Reconnaissance	95.213.200.250	41575	10.0.1.11	32463	N/A	■■■■■■■■■■
Tentativa de Port Scan	Custom Rule Engine-8 : qradar	1	May 6, 2025, 9:49:00 AM	NMAP Reconnaissance	95.213.200.250	41575	10.0.1.11	20789	N/A	■■■■■■■■■■

Receiving an average of 64 results per second.

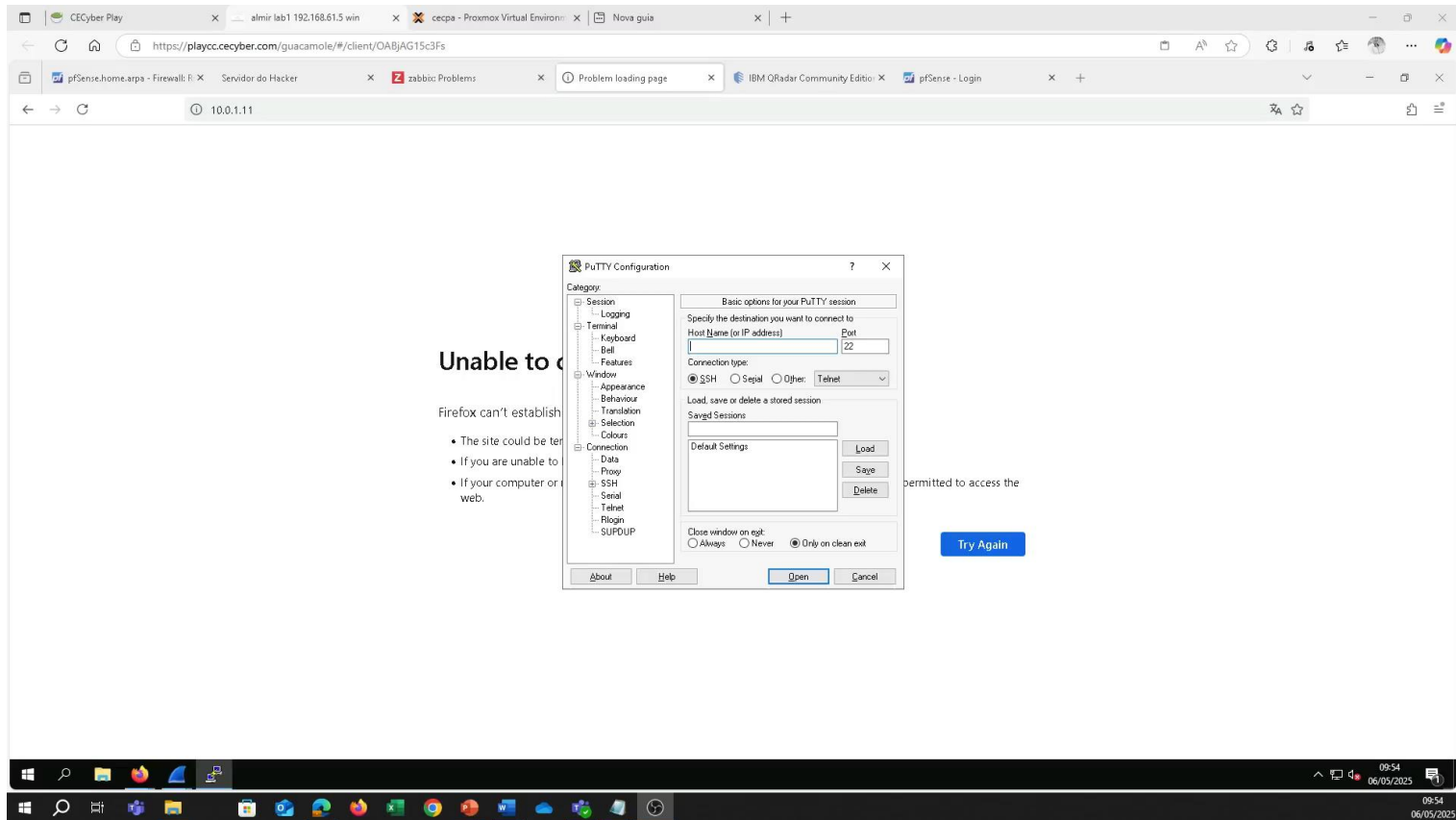
09:49 06/05/2025

09:49 06/05/2025

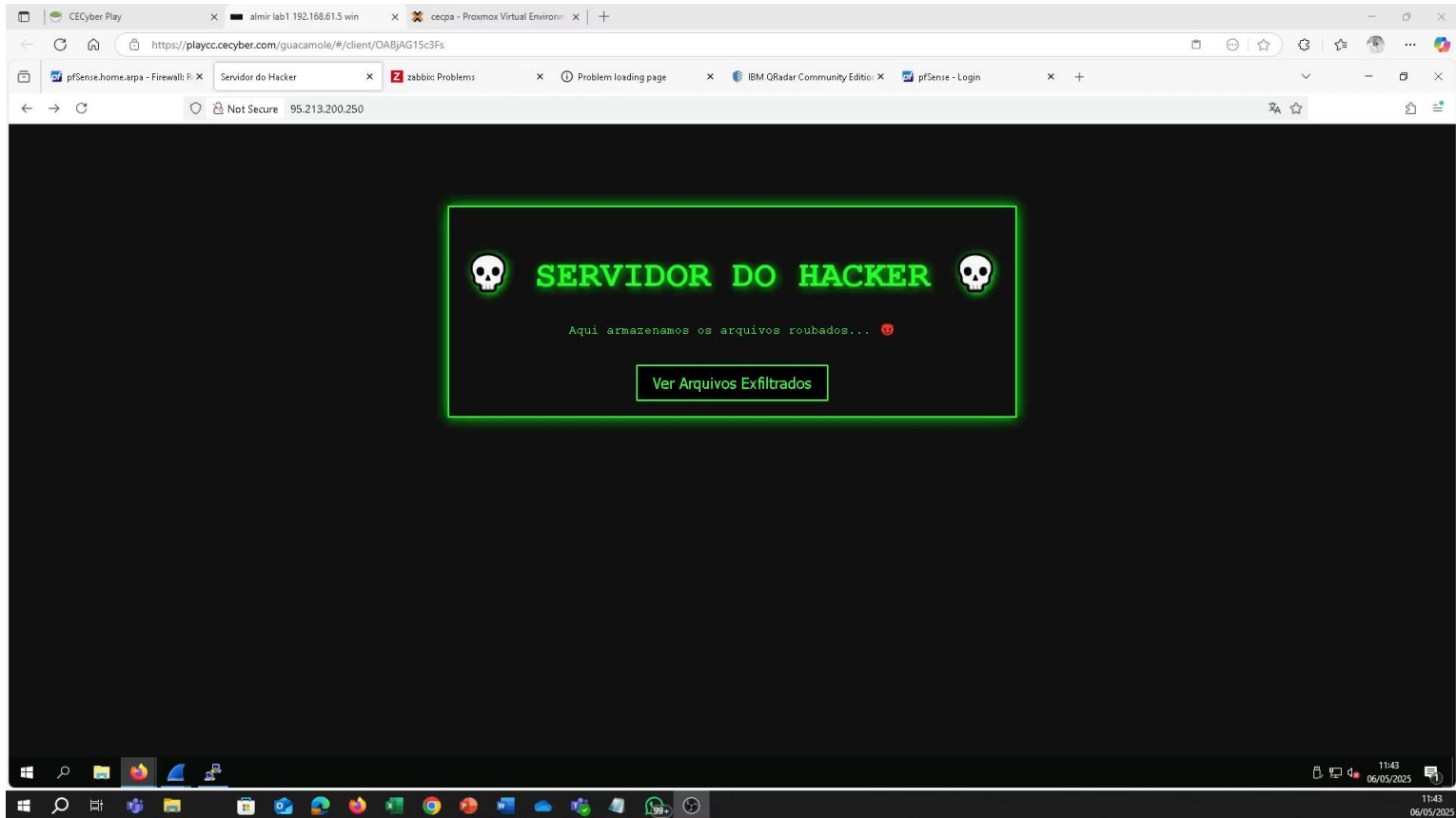
COMO O ATAQUE FOI DETECTADO



QUAL FOI O OBJETIVO DO ATAQUE



QUAL FOI O IMPACTO DO ATAQUE





**CALMA, QUE TUDO QUE ESTÁ RUIM
PODE FICAR PIOR**

CNN.com International - x

172.16.100.23/index-2.html

Apps CNT-Palo CNT-DMZ-Palo QRADAR ZENOSS McAfee Webmin 1.570 on C... BBC Sport - Sport CNT-Palo PA-DMZ

EDITION: INTERNATIONAL U.S. MÉXICO ARABIC

TV: CNNi CNN en Español

Set edition preference

CNN

Sign up Log in

SEARCH

Home Video World U.S. Africa Asia Europe Latin America Middle East Business World Sport Entertainment Tech Travel iReport

Make CNN Your Homepage

ADVERTISMENT

Like 1.2m Follow @cnni

Hi! Log in or sign up to personalize!

SERVIDOR DO HACKER

Aqui armazenamos os arquivos roubados...

Ver Arquivos Exfiltrados

Exclusivo: Empresa brasileira sofre ataque cibernético

Saiba detalhes do ataque que pode causar grande prejuízo para empresa líder de mercado

Opinion: Prepare for al-Assad's exit
Syrians abandoning their homes
Damascus hospital under fire
Syrian crisis zeroes in on Aleppo

U.S. CINEMA MASSACRE

Colorado shooting suspect due in court
Gunman's 'weird' phone message
Shooting vigil | iReport Memorial
Who is suspect? | Survivors' horror

LATEST NEWS

COLORADO MASSACRE

Why are Americans so attached to their guns?

From Washington to the shelves of Walmart, guns are a fact of daily life for millions of Americans. Why is the U.S. obsessed with the right to bear arms?

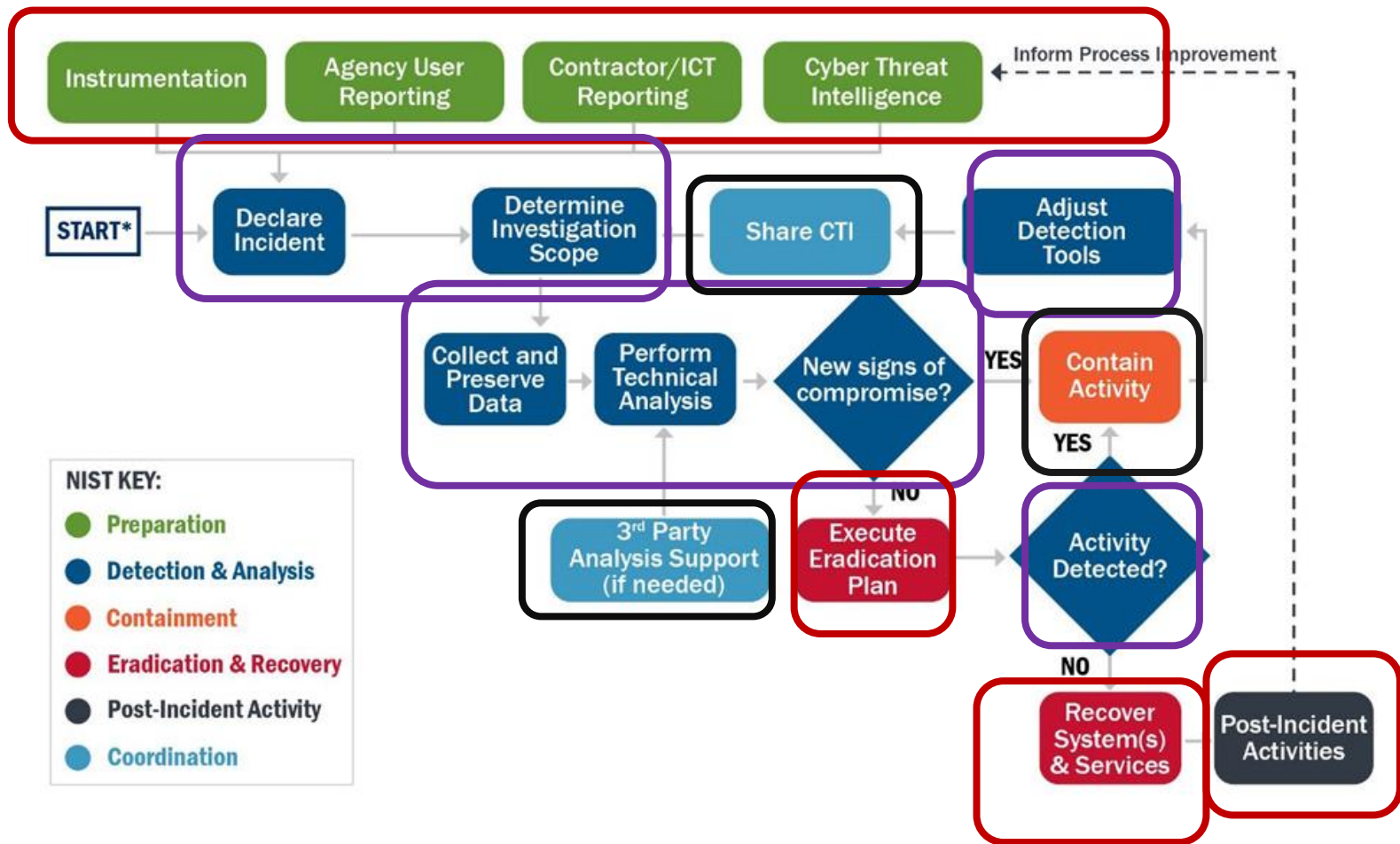
Why U.S. gun laws won't change

FEATURED



**SE O INCIDENTE FOR INEVITÁVEL,
COMO PODEMOS RESPONDÊ-LO DA
MELHOR FORMA POSSÍVEL?
EXISTE UM “PROCESSO” PARA FAZER
ISSO**

FLUXOGRAMA DO PROCESSO DE RESPOSTA A INCIDENTES



ALINHADO SEMPRE COM O NIST CSF



- 1 Scope the Organizational Profile
- 2 Gather needed information
- 3 Create the Organizational Profile
- 4 Analyze gaps and create an action plan
- 5 Implement action plan and update Profile

Repeat...

PARTE 2

**+ RESPONDENDO AO
ATAQUE CIBERNÉTICO**

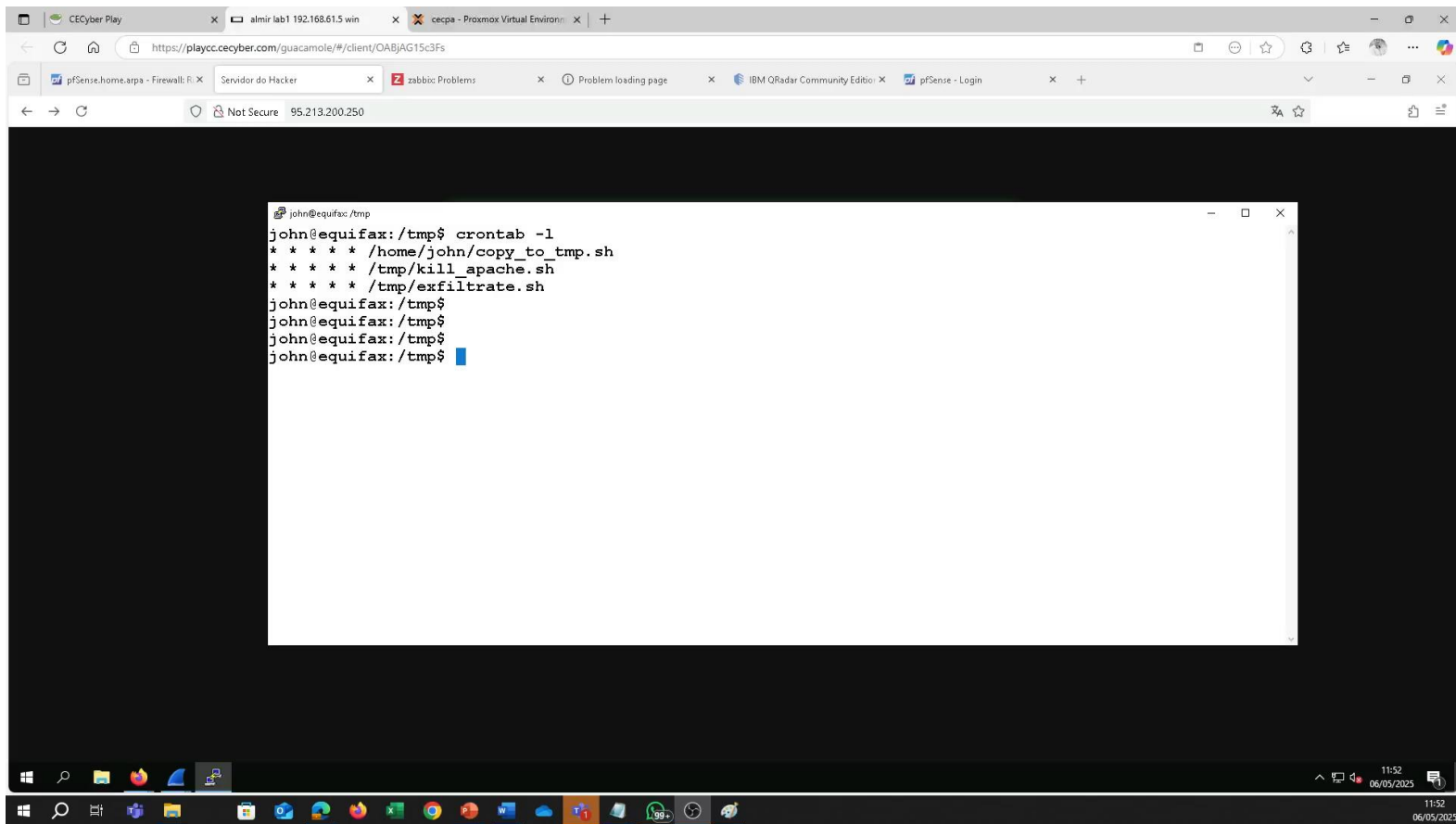
**+ MITIGANDO O ATAQUE
CIBERNÉTICO**





RESPONDENDO AO ATAQUE CIBERNÉTICO

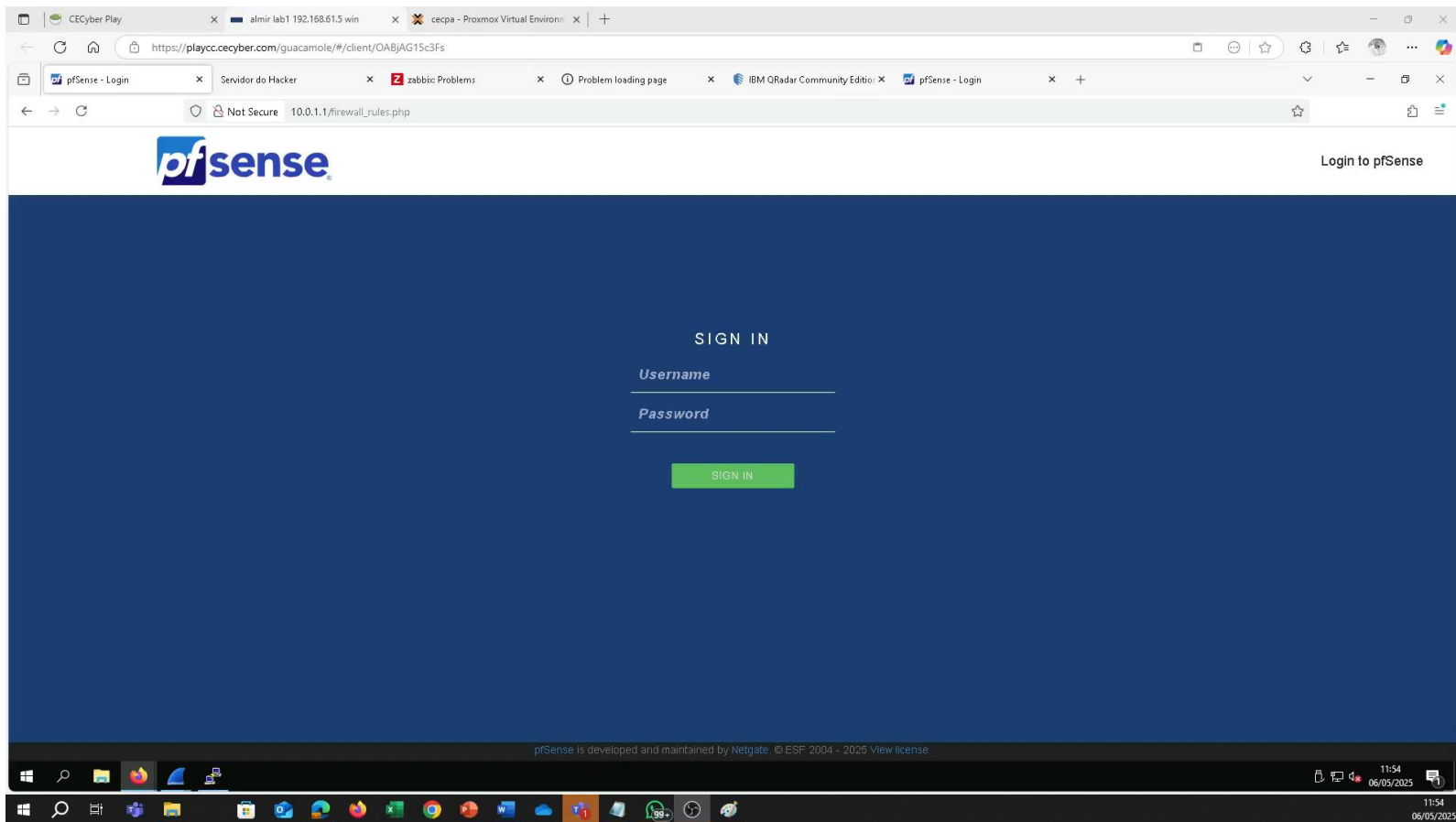
COMO FAZER A CONTENÇÃO



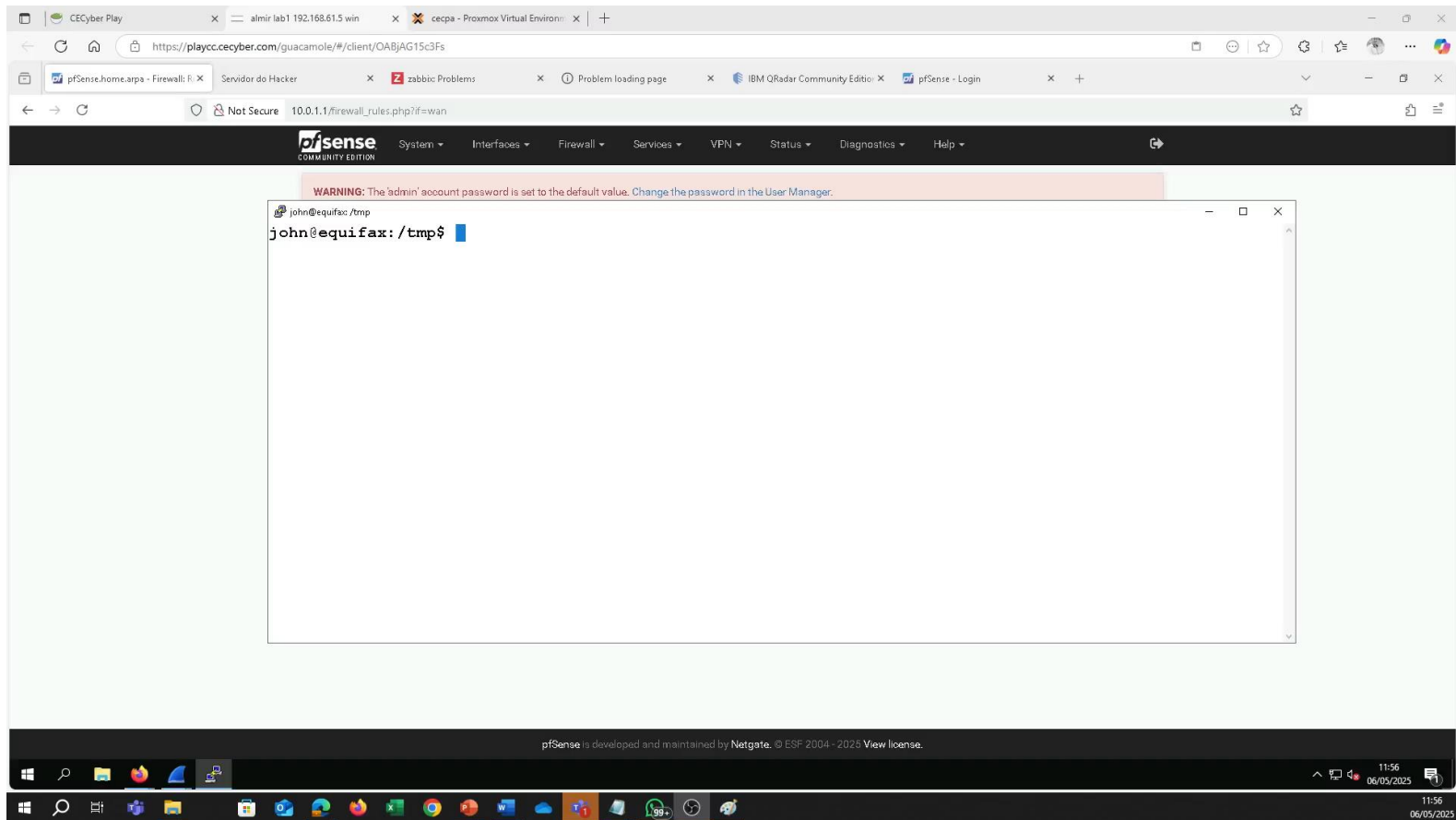
The screenshot shows a web browser window with multiple tabs. The active tab is titled "CECyber Play" and displays the URL "https://playcc.ceciber.com/guacamole/#/client/OABJAG15c3Fs". The browser's address bar shows "Not Secure" and the IP address "95.213.200.250". The main content area of the browser is a terminal window with a black background and white text. The terminal shows a user named "john" at a host named "equifax" in a directory named "tmp". The user has entered the command "crontab -l" to list the current crontab entries. The output shows four entries, all scheduled to run every minute (* * * * *). The first entry runs "/home/john/copy_to_tmp.sh", the second runs "/tmp/kill_apache.sh", and the third runs "/tmp/exfiltrate.sh". The fourth entry is empty. The terminal prompt is currently at "john@equifax: /tmp\$".

```
john@equifax: /tmp$ crontab -l
* * * * * /home/john/copy_to_tmp.sh
* * * * * /tmp/kill_apache.sh
* * * * * /tmp/exfiltrate.sh
john@equifax: /tmp$
john@equifax: /tmp$
john@equifax: /tmp$
john@equifax: /tmp$
```

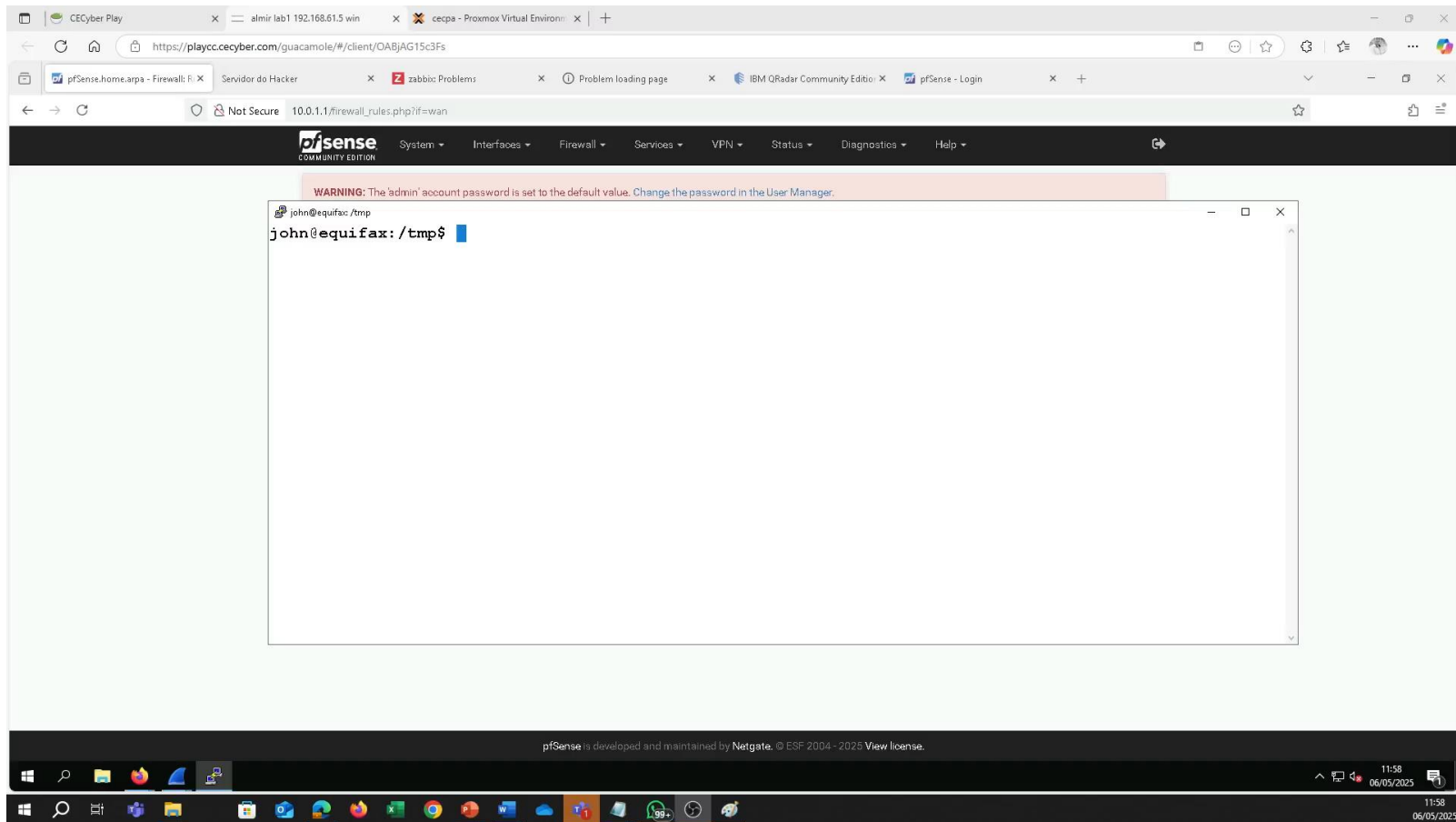
COMO FAZER A RESPOSTA



COMO FAZER A RESPOSTA



COMO FAZER A MITIGAÇÃO





MELHORES PRÁTICAS E DOCUMENTAÇÃO DE APOIO À DECISÃO

E QUAIS SÃO AS MELHORES PRÁTICAS E OS DOCUMENTOS DE REFERÊNCIA?





MACRO ATIVIDADES QUE AUXILIAM NA TOMADA DE DECISÃO

Playbooks e Fluxos Técnicos •Entendimento dos fluxos existentes, TI, Reposta Incidentes e Crises •Criação do fluxo de crises e cross com os fluxos existentes •Correção dos fluxos existentes •Aprovação e documentação dos fluxos	Treinamentos e Simulações, Técnicas •Elaboração do treinamento por atores de TI e SGI (Table Tops) •Apresentação do roteiro de testes por atores •Simulado assistido ator por ator •Simulado assistido fim a fim •Um simulado teste de verificação de resultado •Entrega do calendário de testes e modelos de relatórios	Guia rápido para colaboradores •Elaboração da estrutura do guia •Conscientização em massa do tema incidentes críticos •Revisão do guia •Entrega do guia nos formatos definidos pelas equipes de treinamento	Guia Rápido para Executivos •Elaboração da estrutura do guia •Apresentação do tema incidentes críticos para executivos •Revisão do guia e entrega no formato definido pelas equipes de treinamento	Playbooks e fluxos Líderes de Crises •Definição dos papéis e responsabilidades dos líderes e stakeholders •Criação dos fluxos por líderes em crises ou cross com crises da companhia já mapeado •Apresentação dos fluxos •Aprovação e documentação dos fluxos	Treinamento e simulação Líderes de Crises •Elaboração do treinamento por atores de Liderança (Table Tops) •Apresentação do roteiro de testes por atores •Simulado assistido ator por ator •Simulado assistido fim a fim, atores que se cruzam •Um simulado teste de verificação de resultado •Entrega do calendário de testes e modelos de relatórios	Teste Full do Plano de Reposta a Incidente •Tipo do teste (Table Top) •Testar cada passo do fluxo de resposta incidentes definido •Coletar pontos de falha e lições aprendidas •Fazer a sugestão de correção do plano •Aprovação do novo Plano •Entrega, relatório de testes (usado em auditoria), novo plano e calendário de testes.	Teste Full do Plano de Resposta a Incidentes e CRISES •Tipo do teste (Híbrido) •Elencar casos de uso que serão usado no teste •Elaborar roteiro de ataque junto ao Red Team e BlueTeam •Alinhar roteiro de ação junto as equipes de TI e líderes envolvidos •Alinhar roteiro de ação junto a colaboradores e executivos envolvidos •Construir cenário do teste e definir nível de realidade •Definição de papéis e responsabilidades no corpo diretivo dos testes •Agendar o teste junto a todos os atores •Executar o teste, entregável – Relatório dos observadores. Criar calendarização do teste.
---	---	--	---	--	--	--	--

LIÇÕES APRENDIDAS E RECOMENDAÇÕES

- Anatomia de um ataque cibernético
- Detecção, investigação
- Processo de resposta a incidentes

- Resposta e mitigação
- Melhores práticas de segurança

Almir

Meira Alves

Professor



<https://www.linkedin.com/in/almirmeira/>



almirma@cecyber.com



(11) 9 9466-1953



Podemos contar com o seu feedback?

Escaneie o QR Code ao lado e responda
a nossa **Pesquisa de Avaliação** sobre
esta aula.

